応用情報技術者試験　テクノロジ系　No.11

セキュリティ

情報セキュリティ・情報セキュリティ管理・セキュリティ技術評価・情報セキュリティ対策・セキュリティ実装技術

目次

1. 11-1 情報セキュリティ（19語）
2. 11-2 情報セキュリティ管理（7語）
3. 11-3 セキュリティ技術評価（4語）
4. 11-4 情報セキュリティ対策（12語）
5. 11-5 セキュリティ実装技術（6語）
6. まとめ

11-1 情報セキュリティ まとめ表

情報セキュリティの3要素（CIA）	
要素	**意味**
機密性（Confidentiality）	許された人だけが使える
完全性（Integrity）	正しく、改ざんされていない
可用性（Availability）	必要なときに使える

暗号方式の比較		
方式	**鍵**	**特徴**
共通鍵暗号（AES）	送る側と受ける側で同じ鍵	速い。鍵の受け渡しが課題
公開鍵暗号（RSA・楕円曲線）	公開鍵で暗号化、秘密鍵で復号	遅いが鍵の配送が楽

11-1 情報セキュリティ 基本と暗号

共通鍵暗号方式
Symmetric Key Cryptography

暗号化と復号に同じ鍵を使う方式

ポイント n人がお互いに通信するには n(n−1)/2 個の鍵が要る。代表はAES

公開鍵暗号方式
Public Key Cryptography

公開鍵と秘密鍵の組を使う方式

ポイント 受信者の公開鍵で暗号化し、受信者の秘密鍵で復号する。n人なら2n個

ハイブリッド暗号
Hybrid Encryption

共通鍵を公開鍵暗号で送り、データ本体は共通鍵で暗号化する方式

ポイント TLSで使う

ハッシュ関数
Hash Function

データから決まった長さの値を作る関数

ポイント 元に戻せない、同じ値になる別のデータを見つけにくい。改ざんの検出に使う。例: SHA-256

ディジタル署名
Digital Signature

送信者が自分の秘密鍵で署名し、受信者が送信者の公開鍵で確かめるしくみ

ポイント 送信者の本人確認と改ざんの検出ができる

PKI
ぴーけーあい / Public Key Infrastructure

認証局（CA）が公開鍵の持ち主を証明するしくみ

ポイント ディジタル証明書は認証局の秘密鍵で署名される。失効した証明書はCRLやOCSPで確かめる

Public Key＝公開鍵／Infrastructure＝基盤

11-1 情報セキュリティ 基本と暗号・攻撃の手口

MAC
めっく / Message Authentication Code

共通鍵とデータから作る値で、改ざんを検出する符号

Message＝メッセージ／Authentication＝認証／Code＝符号

ランサムウェア
Ransomware

データを暗号化して使えなくし、元に戻す代わりに金銭を要求するマルウェア

ポイント 対策はオフラインのバックアップ

クロスサイトスクリプティング
XSS / Cross-Site Scripting

Webページに不正なスクリプトを埋め込み、閲覧者のブラウザで実行させる攻撃

ポイント 対策は出力時のエスケープ処理

標的型攻撃
Targeted Attack

特定の組織をねらい、本物らしいメールでマルウェアを送り込む攻撃

ポイント APT（長い期間にわたる攻撃）もある

SQLインジェクション
SQL Injection

入力にSQL文の一部を入れて、データベースを不正に操作する攻撃

ポイント 対策はプレースホルダ（バインド機構）

CSRF
しーさーふ / Cross-Site Request Forgery

ログイン中の利用者に、意図しない処理の要求を送らせる攻撃

ポイント 対策はトークンの確認

Cross-Site＝サイトをまたいだ／Request＝要求／Forgery＝偽造

11-1 情報セキュリティ 攻撃の手口

DDoS攻撃
Distributed Denial of Service Attack

多くの機器から大量の通信を送り、サービスを止める攻撃

Distributed＝分散した／Denial of Service＝サービス妨害

DNSキャッシュポイズニング
DNS Cache Poisoning

DNSサーバに偽の情報を覚えさせ、偽のサイトに誘導する攻撃

中間者攻撃
MITM / Man-in-the-Middle Attack

通信の間に割り込んで、盗み見や改ざんをする攻撃

ゼロデイ攻撃
Zero-day Attack

修正プログラムが出る前に、その弱点（脆弱性）をねらう攻撃

パスワードリスト攻撃
Password List Attack

ほかのサイトから漏れたIDとパスワードの組で、ログインを試す攻撃

ポイント パスワードの使い回しが原因

ソーシャルエンジニアリング
Social Engineering

人の心のすきをついて、パスワードなどを聞き出す手口

例 電話でなりすます、肩越しにのぞく

11-1 情報セキュリティ 攻撃の手口

サイドチャネル攻撃
Side-channel Attack

処理の時間や消費電力などを測って、暗号の鍵を推測する攻撃

11-2 情報セキュリティ管理 まとめ表

リスク対応の4つ	
対応	**意味**
リスク回避	原因となる活動をやめる
リスク低減	対策をして起こる確率や影響を小さくする
リスク移転（共有）	保険や外部委託で他者と分け合う
リスク保有（受容）	影響が小さいので受け入れる

11-2 情報セキュリティ管理 管理のしくみ

ISMS
あいえすえむえす / Information Security Management System

組織で情報セキュリティを管理するしくみ

ポイント JIS Q 27001。PDCAで改善する

Information Security=情報セキュリティ／Management System=管理の仕組み

リスクアセスメント
Risk Assessment

リスクを特定・分析・評価すること

リスク対応
Risk Treatment

評価したリスクに、回避・低減・移転・保有のどれで対応するかを決めること

情報セキュリティポリシ
Information Security Policy

組織の情報セキュリティの方針と規則

ポイント 基本方針・対策基準・実施手順の3階層

CSIRT
しーさーと / Computer Security Incident Response Team

セキュリティ事故（インシデント）に対応する組織

Computer Security=コンピュータの安全／Incident=事故／Response=対応／Team=チーム

SOC
そっく / Security Operation Center

ネットワークを24時間監視して、攻撃を見つける組織

Security=安全／Operation=運用／Center=拠点

11-2 情報セキュリティ管理 管理のしくみ

サイバーセキュリティ経営ガイドライン
Cyber Security Management Guidelines

経営者がセキュリティ対策を進めるために経済産業省とIPAが示した指針

11-3 セキュリティ技術評価 評価の基準

CVSS
しーぶいえすえす / Common Vulnerability Scoring System

脆弱性の深刻さを0〜10の点数で表す共通の基準

Common＝共通の／Vulnerability＝脆弱性／Scoring＝点数付け／System＝方式

ISO/IEC 15408
コモンクライテリア / Common Criteria

IT製品のセキュリティ機能を評価する国際規格

ペネトレーションテスト
Penetration Test

実際に攻撃してみて、侵入できるかを確かめるテスト

ファジング
Fuzzing

予想外のデータを大量に与えて、ソフトウェアの脆弱性を見つける方法

11-4 情報セキュリティ対策 技術的な対策

多要素認証
Multi-factor Authentication

知識（パスワード）・所持（スマホ）・生体（指紋）のうち、2種類以上を組み合わせる認証

ファイアウォール
Firewall

通信を、決めたルールで通したり止めたりする装置

DMZ
でぃーえむぜっと / DeMilitarized Zone

外部と内部のネットワークの間に置く、公開サーバ用の区域

DeMilitarized＝非武装の／Zone＝地帯

WAF
わふ / Web Application Firewall

Webアプリへの攻撃（SQLインジェクションやXSS）を、通信の中身を見て防ぐ装置

Web Application＝Webアプリ／Firewall＝防火壁

IDS・IPS
Intrusion Detection / Prevention System

IDSは不正な侵入を見つけて知らせる、IPSは見つけて止める

Intrusion＝侵入／Detection＝検知／Prevention＝防止

EDR
いーでぃーあーる / Endpoint Detection and Response

パソコンなどの端末で不審な動きを見つけ、すぐに対応するしくみ

Endpoint＝端末／Detection＝検知／Response＝対応

11-4 情報セキュリティ対策 技術的な対策・管理的・物理的な対策

SIEM
しーむ / Security Information and Event Management

いろいろな機器のログをまとめて分析し、攻撃を見つけるしくみ

Security＝安全／Information＝情報／Event＝出来事／Management＝管理

ゼロトラスト
Zero Trust

社内のネットワークでも信用せず、すべてのアクセスを毎回確かめる考え方

デジタルフォレンジックス
Digital Forensics

事故の後、法的な証拠になるようにログやデータを集めて分析すること

最小権限の原則
Principle of Least Privilege

仕事に必要な最小限の権限だけを与えること

セキュアブート
Secure Boot

起動するとき、署名を確かめて正しいソフトウェアだけを動かすしくみ

TPM
てぃーぴーえむ / Trusted Platform Module

鍵の生成や保管を安全に行う、耐タンパ性のあるチップ

Trusted＝信頼された／Platform＝基盤／Module＝部品

11-5 セキュリティ実装技術 安全な通信と開発

TLS
ていーえるえす / Transport Layer Security

通信を暗号化し、サーバの正しさを証明書で確かめるプロトコル

ポイント HTTPSで使う。ハンドシェイクで暗号方式と鍵を決める

Transport Layer=トランスポート層／Security=安全

IPsec
あいぴーせっく / IP Security

IPの層で暗号化と認証を行うプロトコル

ポイント VPNに使う。トンネルモードとトランスポートモード

SPF・DKIM・DMARC

送信元のなりすましを防ぐメールの認証技術

ポイント SPFは送信元のIPアドレス、DKIMは電子署名で確かめる。DMARCは結果に応じた扱いを決める

S/MIME
えすまいむ / Secure MIME

公開鍵を使って、メールを暗号化・署名する方式

Secure=安全な／MIME=メールの形式の規格

セキュアプログラミング
Secure Programming

脆弱性を作らないようにプログラムを書くこと

ポイント 入力のチェック、エスケープ、プレースホルダなど

無線LANのセキュリティ
WPA3

無線LANの暗号化の規格

ポイント WEPは弱く使ってはいけない

まとめ この分野で覚える用語

小分類	用語
11-1 情報セキュリティ	共通鍵暗号方式・公開鍵暗号方式・ハイブリッド暗号・ハッシュ関数・ディジタル署名・PKI・MAC・標的型攻撃・ランサムウェア・SQLインジェクション・クロスサイトスクリプティング・CSRF・DDoS攻撃・DNSキャッシュポイズニング・中間者攻撃・ゼロデイ攻撃・パスワードリスト攻撃・ソーシャルエンジニアリング・サイドチャネル攻撃
11-2 情報セキュリティ管理	ISMS・リスクアセスメント・リスク対応・情報セキュリティポリシ・CSIRT・SOC・サイバーセキュリティ経営ガイドライン
11-3 セキュリティ技術評価	CVSS・ISO/IEC 15408・ペネトレーションテスト・ファジング
11-4 情報セキュリティ対策	多要素認証・ファイアウォール・DMZ・WAF・IDS・IPS・EDR・SIEM・ゼロトラスト・デジタルフォレンジックス・最小権限の原則・セキュアブート・TPM
11-5 セキュリティ実装技術	TLS・IPsec・SPF・DKIM・DMARC・S/MIME・セキュアプログラミング・無線LANのセキュリティ